

An Empirical Evaluation of LLM-Assisted Threat Modeling for SMEs

Vaisakh Narayanan Nair 

Faculty of Electrical Engineering
Technical University of Applied Sciences Augsburg
Augsburg, Germany
vaisakh.narayanan.nair1@tha.de

Abstract—Small and medium-sized enterprises (SMEs) face severe cybersecurity threats but often lack the budgetary resources and in-house expertise required for manual, expert-driven threat modeling. While Large Language Models (LLMs) offer a promising avenue to automate structured threat analysis workflows like STRIDE, their practical utility depends heavily on prompt design. This paper investigates the impact of prompt architecture on LLM-assisted threat modeling by evaluating three strategies: Zero-Shot (ZS), Few-Shot (FS), and Chain-of-Thought (CoT). Utilizing a standardized SME network topology and Gemini 3.1 Pro Preview, we evaluated the generated threat registers against a manually constructed ground-truth baseline. Outputs were quantitatively and qualitatively assessed using an adapted ReCEval rubric measuring Precision, Recall, F1-Score, Correctness, and Informativeness. Results reveal a distinct operational trade-off: CoT prompting maximizes Recall (0.63) and overall F1-Score (0.71) by providing broad coverage across trust boundaries, whereas Few-Shot prompting yields the highest Precision (0.87) and Informativeness by generating highly specific, actionable attack vectors. Based on these findings, we recommend a two-pass LLM pipeline combining CoT for comprehensive baseline mapping with FS for specific mitigation guidance providing SMEs with a scalable, affordable approach to proactive network defense.

Keywords: threat modeling, large language model (LLM), SME, cybersecurity, IT-network

I. INTRODUCTION

Digitalisation has turned even the smallest companies into networked entities that depend on routers, switches, wireless access points, on-premise servers, and cloud services to deliver their core business activities [1]. The same connectivity that drives productivity also enlarges the attack surface. The 2025 ENISA Threat Landscape report attributes 81.1 % of recorded incidents to ransomware and a further 15.2 % to data breaches [2]. The German Federal Office for Information Security characterises the national situation as “tense” and

notes that effective measures are still largely absent for Small and Medium Enterprises (SMEs) [3]. Industry surveys reach a similar conclusion: 82 % of surveyed companies report that they lack a complete inventory of their IT landscape [4].

A central practice in proactive security engineering is *threat modeling*. The STRIDE methodology, introduced at Microsoft and popularised by Howard and Lipner [5], classifies threats into six categories [5], [6]: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. Applied to a Data Flow Diagram (DFD), STRIDE produces a structured threat register that drives subsequent mitigation. The methodology is mature but labour-intensive. For an SME running a hierarchical Cisco network with VLAN segmentation, HSRP redundancy, and a site-to-site VPN, a manual STRIDE pass can occupy several consulting days.

Recent advances in Large Language Models (LLMs) [7] suggest that parts of this workflow can be automated. Reasoning-tuned models can ingest an asset inventory and a DFD and return a STRIDE-compatible register in seconds. However, the practical value of such output depends strongly on how the model is prompted. Zero-Shot (ZS) prompting relies only on the task instruction [8], Few-Shot (FS) prompting injects worked examples that anchor the expected level of specificity [7], and Chain-of-Thought (CoT) prompting forces the model to externalise its reasoning before producing the final register [9]. Existing studies on LLM-assisted threat modeling either focus on telecom-scale architectures [10] or on domain-specific banking pipelines that require fine-tuning [11]. A systematic comparison of these three strategies on an SME-scale network is missing.

This paper addresses that gap. The contribution is threefold:

- A reproducible SME reference architecture is derived from a published academic topology [12], translated into

a twenty-seven-asset inventory and a Level-1 DFD with six trust boundaries.

- An evaluation framework is defined that combines binary True Positive accounting against a ground-truth baseline with ordinal Correctness and Informativeness scales, yielding Precision, Recall, and F1-Score per prompting strategy.
- The three prompting strategies are executed in three independent runs each on Gemini 3.1 Pro Preview at temperature zero, and the resulting threat catalogues are analysed quantitatively and qualitatively.

The remainder of this paper is organised as follows. Section II reviews related work. Section III introduces the SME reference architecture, the prompting strategies, and the evaluation framework. Section IV details the experimental setup. Section V presents the results. Section VI discusses implications, limitations, and threats to validity. Section VII concludes and outlines future work.

II. RELATED WORK

Threat modeling has a rich history in software security. Shostack consolidated decades of practice into a four-question framework supported by manual DFD construction and STRIDE classification [6]. Howard and Lipner integrated STRIDE into the Microsoft Security Development Lifecycle [5]. Both works assume the availability of dedicated security experts and substantial documentation effort. Khan et al. applied STRIDE to cyber-physical smart-grid systems and demonstrated component-level traceability, but again under the assumption that an expert performs the analysis [13].

The systematic literature review by Xiong and Lagerström over 176 papers concludes that manual effort and validation gaps remain the dominant pain points [14].

Several recent works examine LLM-assisted threat modeling. AbdulGhaffar and Matrawy compare four prompting strategies across five LLMs on 5G telecom scenarios, restricting the task to STRIDE classification without producing DFDs or mitigation plans [10]. Wu et al. propose an end-to-end pipeline for banking systems that combines CoT and Few-Shot prompting with LoRA fine-tuning, achieving strong reproducibility at temperature zero [11]. The fine-tuning requirement, however, contradicts the affordability principle that characterises SME deployments. Prasad et al. introduce ReCEval, a bidimensional reasoning-chain evaluation framework that scores intermediate reasoning steps along correctness and informativeness axes [15]. Their work is not specific to cybersecurity and requires adaptation for threat modeling.

The SME perspective itself has been examined by Junior et al., who reviewed 132 papers and identify a persistent “unaware, unfunded, untrained, and unsupported” pattern [1]. Their work emphasises the gap analysis but does not propose a technical solution. In contrast, this paper combines an SME-scale topology, the three most common prompting strategies, and a ReCEval-inspired evaluation rubric to study how prompt design influences the quality of LLM-generated STRIDE threat registers.

III. METHODOLOGY

The methodology defines the inputs, the prompting strategies, and the evaluation metrics required to compare LLM behaviour across prompting strategies on an SME network. The workflow follows a four-layer prompt architecture that separates persona, context, task, and constraints. Only the task layer changes between the experimental conditions.

A. SME Reference Architecture

The reference network is derived from a published academic topology that documents a representative SME deployment with hierarchical Cisco infrastructure [12]. The topology covers a small healthcare clinic and a small manufacturer that share the same network template. The architecture contains a perimeter router, a Cisco 5506-X edge firewall, two redundant core multilayer switches with HSRP gateway redundancy, three distribution switches, an access layer that segments six departments into VLANs 10 through 60, a DMZ hosting DNS, DHCP, and Web services, a wireless zone, and a remote corporate branch connected via an IPsec site-to-site VPN tunnel. Inter-VLAN routing relies on OSPF, and Access Control Lists (ACLs) enforce traffic separation between zones.

The architecture is captured in an asset inventory of twenty-seven items (AS-01 to AS-27) covering five categories: network devices, end-user devices, servers and services, data stores, and external interfaces. Each asset records the attributes that are observable from the source publication, namely model, firmware version where available, exposed ports, authentication method, and data classification. Some attributes (operating system, patch level, specific model variants) are incomplete in the source material. This limitation is preserved deliberately in the inventory so that the LLM is forced to reason under realistic information asymmetry rather than under a curated dataset.

The Level-1 DFD encodes six trust boundaries [6] (Operator Part, Core Layer, Distribution Layer, DMZ Zone, Access Layer, Wireless Zone, and Corporate Division) and the data flows between them. The DFD is rendered in Mermaid syntax [16] to keep the artefact lightweight and platform-independent.

B. Prompting Strategies

Three prompting strategies are evaluated:

Zero-Shot (ZS). The task instruction asks the model to perform a systematic STRIDE analysis on every external entity, process, data store, and data flow in the DFD without any worked example.

Few-Shot (FS). The same task instruction is augmented with three worked examples that demonstrate the expected specificity. The first example covers a Workstation-to-File-Server SMB data flow and a Tampering threat realised through an SMB relay attack. The second example covers a VPN gateway and a Spoofing threat realised through a credential replay attack. The third example covers a Web-Application-to-Database TLS flow and an Information Disclosure threat realised through TLS downgrade. The choice of three examples is informed by the theoretical analysis of shot count

Table I: Case Study Asset Inventory

Asset ID	Asset Name (Zone / Dept)	Asset Category	Attributes
AS-01	Router-Headquarters	Network devices	Model: Cisco 2811
AS-02	5505-X Firewall (Edge)	Network devices	Model: Cisco 5506-X
AS-03	Core-SW1 & Core-SW2	Network devices	Model: Cisco 3560-24PS
AS-04	Switches: HJ-SW1, HJ-SW2, HJ-SW3	Network devices	Model: Cisco 3560-24PS
AS-05	Switch4 (DMZ Zone)	Network devices	Model: Cisco 2960-24TT
AS-06	PC13 (DMZ Zone)	End-user devices	Model: PC-PT
AS-07	Server-PT DNS (DMZ Zone)	Servers & services	Exposed ports: DNS implied
AS-08	Server-PT DHCP (DMZ Zone)	Servers & services	Exposed ports: DHCP implied
AS-09	Server-PT Web (DMZ Zone)	Servers & services	Exposed ports: Web implied
AS-10	Router 6 & Switch 5 (Operation Part)	Network devices	Model: Cisco 2811 & Cisco 2960-24TT respectively
AS-11	Server-PT DNS 2 & Web 2 (Operation Part)	Servers & services	Exposed ports: DNS/Web implied
AS-12	PC0, User 1, User 2 (Operation Part)	End-user devices	
AS-13	Switch JR-SW1 (Admin - VLAN 10)	Network devices	Model: Cisco 2950-24
AS-14	PC01 (Admin - VLAN 10)	End-user devices	
AS-15	Access Point 0 (Wireless Zone)	Network devices	Model: AccessPoint-PT
AS-16	Laptop0 & Smartphone0 (Wireless Zone)	End-user devices	
AS-17	Switch JR-SW2 & PC02, PC03 (Marketing - VLAN 20)	Network dev. & End-user	Model: Cisco 2960-24TT
AS-18	Switch JR-SW3 & PC04, PC05 (Sales - VLAN 30)	Network dev. & End-user	Model: Cisco 2960-24TT
AS-19	Switch JR-SW4 & PC06, PC07 (Finance - VLAN 40)	Network dev. & End-user	Model: Cisco 2960-24TT
AS-20	Switch JR-SW5 & PC08, PC09 (Production - VLAN 50)	Network dev. & End-user	Model: Cisco 2960-24TT
AS-21	Switch JR-SW6 & PC10, PC11 (Logistics - VLAN 60)	Network dev. & End-user	Model: Cisco 2960-24TT
AS-22	Router-Branch (Corporate Branch)	Network devices	Model: Cisco 2811
AS-23	Branch Core Switch HJ-SW11 (Corporate Branch)	Network devices	Model: Cisco 3560-24PS
AS-24	Switch JR-SW1(1) & PC21, PC22 (Branch Prod - VLAN 10)	Network dev. & End-user	Model: Cisco 2950-24TT
AS-25	Switch JR-SW1(2) & PC23, PC24 (Branch Sales - VLAN 20)	Network dev. & End-user	Model: Cisco 2960-24TT
AS-26	Enterprise Data (Conceptual)	Data stores	Classification: Patient records, payment data mentioned conceptually
AS-27	Site-to-Site VPN Tunnel	External interfaces	Protocol: IPsec ESP (AES-256) Auth: PSK via IKEv2 / HMAC-SHA-256 Data direction: Inter-site

by Cao et al. [17], which shows that the marginal benefit of additional shots diminishes rapidly and that small numbers of high-quality examples are sufficient for structured generation tasks.

Chain-of-Thought (CoT). The task instruction asks the model to write out an explicit four-step reasoning chain for every DFD element (what the element does, who interacts with it, which STRIDE categories apply, and what the specific attack vector is) before emitting the final threat register.

All three strategies share the same system prompt, context injection, and output-constraint layer. The constraint layer mandates a single Markdown table with six fixed columns (Threat ID, DFD Element, STRIDE Category, Threat Description, Affected Security Property, Severity), one row per threat,

and a description that names a concrete attack vector rather than restating the STRIDE category definition.

C. Prompt Architecture

Each Phase of the Workflow uses a four-layer prompt structure (refer III) to control the LLM-model behavior without requiring the SME employee to write the prompt from scratch. The layers have distinct responsibilities and are kept separate to prevent the model from confusing role, context, task, and constraints.

Only the Context Injection layer changes between SME deployments. The separation of concerns also provides a security property: network-specific data enters only through the Context Injection layer and never mixes with task instruc-

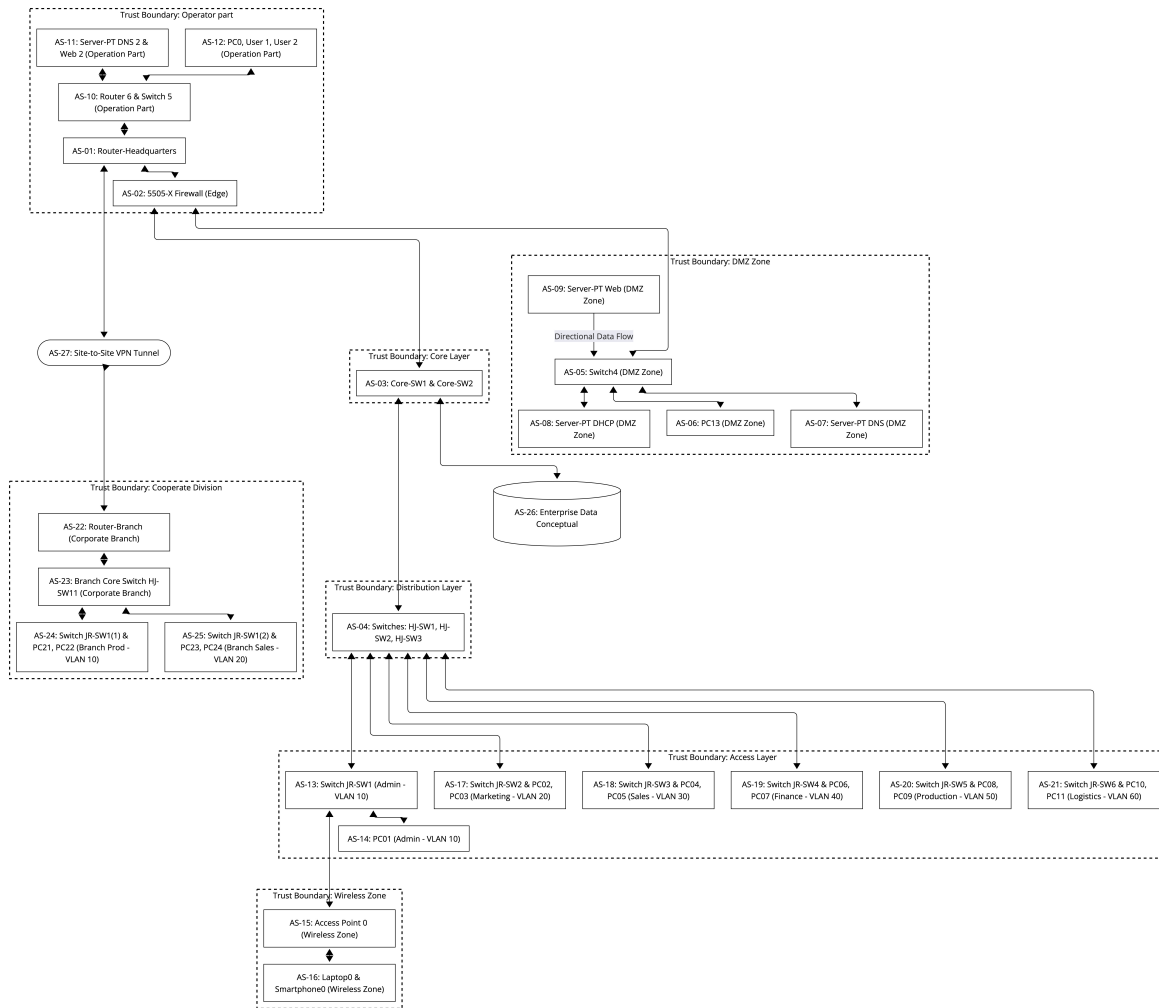


Figure 1: Case Study Data Flow Diagram (Phase 2 Output injected into Layer 2)

tions, preventing a malicious asset description from overriding framework reasoning instructions.

1) *System Prompt (Layer 1)*: This layer is fixed across the experiment and establishes the persona and scope for the LLM.

[System Prompt]

You are an expert IT-Security consultant specializing in threat modeling for Small and Medium Enterprises (SMEs). Your role is to analyze small IT networks and identify specific, actionable security threats using the STRIDE methodology. You communicate clearly, focusing on practical attack vectors rather than theoretical concepts.

2) *Context Injection (Layer 2)*: This layer dynamically injects the human-validated outputs from Phase 1 and Phase 2. For this experiment, the LLM is provided with the Case Study Asset Inventory (detailed in Table I) and the Data Flow Diagram (illustrated in Figure 1).

[Context Injection]

Below is the network context for the SME.

ASSET INVENTORY: [Inserted Table I]

DATA FLOW DIAGRAM (DFD): [Inserted Figure 1]

3) *Task Prompts (Layer 3)*: This is the experimental variable. There are three variable conditions, each representing a distinct prompting strategy.

[Condition A: Zero Shot (ZS)]

TASK INSTRUCTION: Conduct a systematic STRIDE threat analysis on the provided network. Evaluate every external entity, process, data store, and data flow in the DFD. Identify applicable threats across all six STRIDE categories (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) based on the asset inventory details.

[Condition B: Few Shot (FS)]

TASK INSTRUCTION: Conduct a systematic STRIDE threat analysis on the provided network. Evaluate every external entity, process, data store, and data flow in the DFD against all six STRIDE categories. To guide your analysis, here are two examples of the expected specificity:

Table II: Ground-Truth STRIDE Coverage Baseline

ID	Asset (short)	S	T	R	I	D	E
AS-01	Router-HQ	✓				✓	
AS-02	Edge Firewall	✓				✓	
AS-03	Core-SW1/SW2		✓	✓			✓
AS-04	Distribution Switches		✓				
AS-05	DMZ Switch4	✓				✓	
AS-06	DMZ PC13	✓					✓
AS-07	DMZ DNS Server	✓	✓			✓	
AS-08	DMZ DHCP Server	✓				✓	
AS-09	DMZ Web Server	✓	✓		✓	✓	
AS-10	Router 6 & SW 5	✓	✓			✓	
AS-11	Operator DNS/Web 2	✓	✓		✓	✓	
AS-12	Operator End-users	✓		✓	✓		✓
AS-13	Admin Switch JR-SW1	✓	✓				
AS-14	Admin PC01	✓		✓	✓		✓
AS-15	Wireless AP	✓	✓		✓	✓	
AS-16	Wireless Clients	✓		✓	✓		
AS-17	Marketing VLAN 20	✓		✓			✓
AS-18	Sales VLAN 30	✓		✓			✓
AS-19	Finance VLAN 40	✓		✓	✓		✓
AS-20	Production VLAN 50	✓		✓			✓
AS-21	Logistics VLAN 60	✓		✓			✓
AS-22	Branch Router	✓				✓	
AS-23	Branch Core Switch		✓	✓			✓
AS-24	Branch Prod VLAN 10	✓		✓			✓
AS-25	Branch Sales VLAN 20	✓		✓			✓
AS-26	Enterprise Data Store		✓		✓	✓	
AS-27	Site-to-Site VPN		✓		✓	✓	

Table III: Four-layer prompt architecture

Layer	Controls
System Prompt	Model persona, role, scope
Context Injection	Network-specific facts
Task Prompt	Phase-specific instruction (varies by strategy)
Constraint Prompt	Output format, column headers, forbidden behaviors

Example 1: DFD Element: Workstation-to-File-Server
SMB Data Flow | STRIDE Category: Tampering | Threat Description: An internal attacker or compromised endpoint performs an SMB relay attack to intercept and modify unencrypted financial data in transit to the NAS.

Example 2: DFD Element: VPN Gateway | STRIDE Category: Spoofing | Threat Description: An external attacker executes a credential replay attack using stolen credentials obtained from a phishing campaign to bypass single-factor authentication on the VPN gateway.

[Condition C: Chain-of-Thought (CoT)]
TASK INSTRUCTION: Conduct a systematic STRIDE threat analysis on the provided network. Evaluate every external entity, process, data store, and data flow in the DFD against all six STRIDE categories. Before generating the final Threat Register table, you must explicitly reason through your analysis step-by-step. For every DFD element, write out the following reasoning chain: 1) What does this element do? 2) Who or what interacts with it? 3)

Which of the six STRIDE categories apply to it, given the specific hardware, software, and access methods listed in the asset inventory? 4) What is the specific attack vector for each applicable category? Only after completing this step-by-step reasoning for all elements should you output the final Threat Register table.

4) *Constraint Prompt (Layer 4)*: This layer enforces the structural output requirements, ensuring the results are machine-readable and standardized.

[Constraint Prompt (Layer 4)]

OUTPUT CONSTRAINTS: 1) You must output the final result as a single Markdown table. 2) The table must use exactly these column headers: Threat ID, DFD Element, STRIDE Category, Threat Description, Affected Security Property, Severity. 3) Severity must be strictly categorized as High, Medium, or Low. 4) Output exactly one row per identified threat. 5) Do not include rows for inapplicable STRIDE categories. 6) The Threat Description MUST name a specific attack vector (e.g., "attacker exploits unpatched SMB vulnerability") and MUST NOT simply restate the STRIDE category definition.

D. Evaluation Framework

The evaluation framework is inspired by ReCEval [15] and is adapted to the threat-modeling setting. Each LLM-generated threat is scored along two ordinal axes and one binary axis against a ground-truth baseline.

The ground-truth baseline is a manually constructed STRIDE coverage matrix that, for each of the twenty-seven assets, lists the STRIDE categories that are technically applicable given the architecture. The baseline was produced by a single rater based on the asset inventory and the DFD. It contains the union of threat categories that an expert would expect to see in a thorough analysis. The ground-truth baseline used in this study is shown in Table II.

The following variables are recorded for every LLM-generated threat:

- **Correctness (0/1)**. A value of one is assigned when the proposed threat is technically possible on the documented architecture. A value of zero is assigned when the threat is hallucinated, technically impossible, or irrelevant.
- **Informativeness (0/1/2)**. A value of zero indicates a generic threat that restates the STRIDE definition. A value of one indicates a vague but contextually plausible threat. A value of two indicates a highly specific attack vector that names protocols, devices, or configurations from the inventory.
- **True Positive (TP)**. A threat is counted as a True Positive when it maps logically onto an entry of the ground-truth baseline. False Positives are threats that are technically impossible, hallucinated, or irrelevant.

From these variables, three aggregate metrics [18] are derived per prompting strategy:

$$\text{Precision} = \frac{TP}{TP + FP} \quad (1)$$

$$\text{Recall} = \frac{TP}{|\text{Baseline}|} \quad (2)$$

$$F1 = 2 \cdot \frac{\text{Precision} \cdot \text{Recall}}{\text{Precision} + \text{Recall}} \quad (3)$$

Precision measures the noise level of the LLM output. Recall measures the coverage of the technically relevant threats. F1 balances both perspectives.

Worked Scoring Example

Consider threat T-01 from the Gemini Zero-Shot run #1: “Attacker conducts MAC address spoofing or deploys a rogue access point to bypass wireless access controls on AS-15.”

- **Correctness = 1.** A rogue access point attack is technically feasible on the documented `AccessPoint-PT` device in the Wireless Zone.
- **Informativeness = 2.** The description names a concrete attack vector (MAC spoofing, rogue AP) and binds it to a specific asset rather than restating the Spoofing definition.
- **True Positive = yes.** The baseline (Table II) lists Spoofing as applicable to AS-15, and the threat targets the same asset and the same STRIDE category.

A contrasting case is threat T-02 from the same run: “Attacker attempts an offline dictionary attack against the IKEv2 Pre-Shared Key on AS-27.” The threat scores Correctness = 1 and Informativeness = 2, but it is counted as a False Positive because the baseline does not list Spoofing as applicable to AS-27; the VPN tunnel is associated with Tampering, Information Disclosure, and Denial of Service in the baseline.

IV. EXPERIMENTAL SETUP

The experiment was executed in late spring 2026 using Gemini 3.1 Pro Preview accessed through its public API [19]. The model was released on 12 February 2026, has a January 2025 knowledge cut-off, and represents the current state-of-the-art reasoning tier of the Gemini family. The thinking level was set to High, the temperature was fixed at zero, and all other sampling parameters were left at their default values. These choices were made to minimise stochastic variation and to maximise reproducibility.

Each of the three prompting strategies was executed three times against the asset inventory and DFD described in Section III-A. Independent runs remain necessary because reasoning-tuned models are not fully deterministic at temperature zero [20]. The three runs per condition expose the residual non-determinism that affects practical reproducibility.

Two researchers independently graded the resulting nine threat registers using the rubric defined in Section III-D (with inter-rater reliability assessed via methodologies such as Cohen’s kappa [21]). Disagreements were resolved through discussion. The graded data were aggregated per prompting

strategy and per STRIDE category. The full grading procedure is detailed in Section IV-A.

A. From Raw Output to Metrics: Grading Procedure

The path from raw LLM output to the aggregated metrics reported in Section V follows a four-step procedure designed to maximize transparency and reproducibility.

Step 1: Raw data collection. Each of the nine runs produced a Markdown threat register that conforms to the Layer-4 constraint prompt (six columns, one row per threat). The nine registers were imported into a spreadsheet-based experiment tracker yielding a combined corpus of 122 individual threat entries.

Step 2: Per-row annotation. Every threat row was annotated manually using three controlled labels drawn from the rubric defined in Section III-D: a binary True Positive flag, a binary Correctness score, and an ordinal Informativeness score on a 0–2 scale. The annotation was performed in a fixed column order to prevent the rater from inferring the aggregated outcome before scoring an individual row.

Step 3: Ground-truth mapping. Each generated threat was compared against the baseline matrix shown in Table II. A True Positive requires two simultaneous conditions: the asset referenced by the LLM must correspond to a baseline asset, and the STRIDE category proposed by the LLM must be present for that asset in the baseline. Threats that name a technically valid attack but target an asset or category absent from the baseline were recorded as False Positives.

Step 4: Aggregation. Within a single run, duplicate entries that point to the same asset and the same STRIDE category were collapsed into one before counting. Precision, Recall, and F1-Score were computed for each individual run and then averaged across the three runs of a strategy. The averaged values are reported in Table V. Mean Correctness and mean Informativeness were computed over all threats produced by a strategy without deduplication, because both scores describe individual rows rather than aggregated coverage.

V. RESULTS

The nine experimental runs produced threat catalogues whose size and shape differ markedly between strategies. The Zero-Shot runs generated between eleven and twelve threats, the Few-Shot runs between nine and eleven threats, and the Chain-of-Thought runs between sixteen and twenty-one threats. The CoT runs occasionally collapsed individual assets into broader zones (for example “DMZ Zone” or “Core Layer”) when the model determined that several assets share the same threat surface.

A. Coverage of the Ground-Truth Baseline

Table IV summarises the STRIDE coverage of each prompting strategy aggregated over the three runs. The table reports, for every asset, whether the strategy generated at least one threat in each STRIDE category at least once across the three runs.

Two observations stand out. First, the Chain-of-Thought strategy achieves the broadest coverage and is the only strategy

Table IV: Aggregated STRIDE Coverage per Prompting Strategy. Cells indicate the number of runs (out of three) in which the corresponding asset received at least one threat in any STRIDE category.

Asset group	ZS	FS	CoT
Edge devices (AS-01, AS-02)	2/3	3/3	3/3
Core switches (AS-03)	3/3	3/3	3/3
Distribution (AS-04)	0/3	1/3	3/3
DMZ (AS-05–AS-09)	3/3	2/3	3/3
Operator part (AS-10–AS-12)	0/3	0/3	3/3
Access layer (AS-13–AS-21)	3/3	3/3	3/3
Wireless (AS-15, AS-16)	3/3	3/3	3/3
Branch (AS-22–AS-25)	0/3	0/3	0/3
Data store (AS-26)	3/3	2/3	3/3
VPN tunnel (AS-27)	2/3	3/3	3/3

Table V: Aggregated Evaluation Metrics per Prompting Strategy.

Metric	ZS	FS	CoT
Generated threats (mean)	11.7	10.3	18.3
True Positives (mean)	9.3	9.0	14.7
Precision	0.79	0.87	0.80
Recall (vs. baseline)	0.40	0.39	0.63
F1-Score	0.53	0.54	0.71
Mean Correctness	0.91	0.94	0.92
Mean Informativeness	1.4	1.8	1.6

that consistently produces threats for the Distribution Layer and the Operator Part. Second, none of the three strategies generates threats for the Corporate Branch assets (AS-22 through AS-25) in any run. This blind spot persists even though the asset inventory and the DFD describe the branch infrastructure explicitly.

B. Precision, Recall, and F1-Score

Table V reports the aggregated Precision, Recall, and F1-Score per prompting strategy. The values are computed across all three runs of each strategy after deduplicating threats that point to the same asset and STRIDE category. Figure 2 visualises the same comparison across all five headline metrics.

Few-Shot prompting produces the highest Precision and the highest mean Informativeness score, which is consistent with the design intent of the FS examples. The examples in the prompt anchor the model on naming concrete protocols and attack steps. Chain-of-Thought prompting produces the highest Recall and the highest F1-Score, aligning with findings that CoT elicits deeper reasoning paths [8], [9]. Zero-Shot prompting trails on both the Precision and the Recall axes and exhibits the largest variance between runs.

C. Qualitative Patterns

A qualitative inspection of the threat descriptions reveals three recurring patterns. First, ZS prompting frequently generates threats whose description matches the STRIDE category definition without naming a specific attack vector. For example, ZS run #3 produced “Attacker attempts to spoof

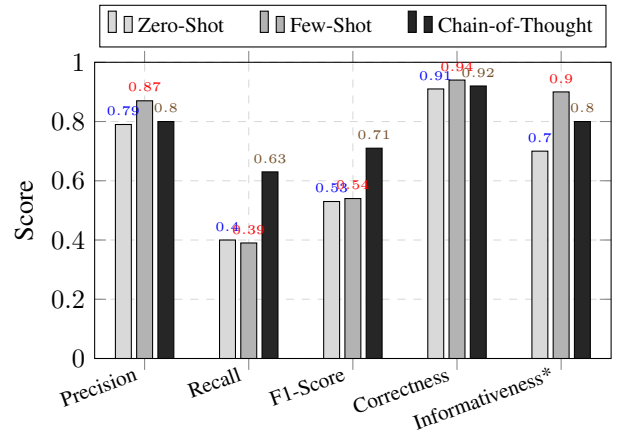


Figure 2: Aggregated evaluation metrics per prompting strategy. Higher bars indicate better performance. Few-Shot prompting leads on Precision and Informativeness, while Chain-of-Thought prompting maximises Recall and F1-Score. Informativeness is normalised to the $[0, 1]$ range by dividing the mean ordinal score by 2.

a legitimate user” for the wireless access point, which is technically valid but operationally vague.

Second, FS prompting produces highly specific descriptions that mirror the structure of the worked examples. The FS runs consistently name attack vectors such as “Evil Twin rogue access point”, “IKEv2 PSK offline dictionary attack”, and “HSRP priority hijacking”.

Third, CoT prompting tends to abstract multiple assets into a broader trust zone in roughly two thirds of its threats. This pattern increases coverage but reduces traceability to individual assets. CoT run #2 explicitly grouped the DMZ DNS, DHCP, and Web servers into a single “DMZ Zone” threat entry, which conflates three assets with different exposed ports and different authentication surfaces.

VI. DISCUSSION

The results indicate that no single prompting strategy dominates on every metric. The choice of strategy involves a trade-off between specificity, coverage, and traceability.

A. Implications for SME Practice

For an SME that integrates an LLM into a lightweight threat-modeling pipeline, the results suggest a two-pass approach. A CoT pass first generates a broad coverage map, after which an FS pass enriches selected entries with concrete attack vectors. The combination harvests the coverage strength of CoT and the specificity strength of FS while keeping the total token cost bounded. Pure ZS prompting offers limited operational value because its descriptions are too generic to drive mitigation decisions, although it remains useful as a smoke-test baseline.

The persistent blind spot on the Corporate Branch assets is a more concerning finding. The DFD describes the branch

as a separate trust boundary connected through the site-to-site VPN, and a thorough analysis should produce threats for the branch routers and switches. The model appears to treat the branch as implicitly covered by the VPN tunnel threat. This is likely related to the ‘lost in the middle’ phenomenon where models degrade on information placed centrally in long contexts [22]. This pattern suggests that a meta-prompt enforcing per-asset enumeration would improve completeness.

B. Limitations

The study is subject to several limitations. The experiment uses a single LLM (Gemini 3.1 Pro Preview) and a single network topology. Generalisation across model providers and across architectures requires further work. The ground-truth baseline was constructed by a single rater and reflects an expert opinion that may diverge from other expert opinions, although the asset inventory and DFD were shared transparently to enable replication. The three independent runs per condition give a first estimate of residual non-determinism at temperature zero, but a larger run count would tighten the confidence intervals on the reported metrics.

C. Threats to Validity

The internal validity of the experiment is supported by the fixed system prompt, the fixed constraint prompt, the fixed temperature, and the use of an identical asset inventory and DFD across all conditions. The construct validity rests on the ReCEval-inspired rubric, which separates the binary baseline-matching dimension from the ordinal Correctness and Informativeness axes. The external validity is bounded by the choice of one model and one topology. Future studies should replicate the design across at least three model providers and at least three SME topologies of varying size to estimate the robustness of the prompting-strategy ranking.

VII. CONCLUSION

This paper examined how three prompting strategies, namely Zero-Shot, Few-Shot, and Chain-of-Thought, affect the quality of LLM-generated STRIDE threat registers for an SME-scale network. A reproducible reference architecture derived from a published academic topology was translated into a twenty-seven-asset inventory and a Level-1 DFD with six trust boundaries. The three strategies were executed in three independent runs each on Gemini 3.1 Pro Preview at temperature zero and graded against a manually constructed ground-truth baseline using Precision, Recall, F1-Score, Correctness, and Informativeness. The results show that Chain-of-Thought prompting maximises coverage and F1-Score, Few-Shot prompting maximises specificity and Precision, and Zero-Shot prompting trails on every metric and shows the largest run-to-run variance. A persistent blind spot on the Corporate Branch assets was observed across all strategies.

Returning to the original motivation, SMEs lack the budget and the expertise to commission deep threat-modeling engagements. The evidence presented here indicates that a careful combination of prompting strategies can deliver actionable

threat catalogues at a cost compatible with SME constraints, while also revealing failure modes that require human review. Future work will extend the comparison to additional model providers, replicate the design across multiple topologies, and quantify the cost and latency of the proposed two-pass CoT-then-FS pipeline. A broader research agenda should also evaluate the resilience of the prompt architecture against adversarial asset descriptions and indirect prompt-injection attacks [23], given that LLM-assisted threat modeling is itself becoming a critical step in the security supply chain of SMEs.

REFERENCES

- [1] C. R. Junior, I. Becker, and S. D. Johnson, “Unaware, Unfunded, Untrained and Unsupported: A Systematic Review of SME Cybersecurity,” arXiv:2309.17186, 2023.
- [2] European Union Agency for Cybersecurity, “ENISA Threat Landscape 2025,” ENISA, Heraklion, Greece, Tech. Rep., Oct. 2025.
- [3] Bundesamt für Sicherheit in der Informationstechnik, “Die Lage der IT-Sicherheit in Deutschland 2025,” BSI, Bonn, Germany, Nov. 2025.
- [4] TÜV-Verband, “Cybersicherheit in deutschen Unternehmen: TÜV Cybersecurity Studie 2025,” Berlin, Germany, 2025.
- [5] M. Howard and S. Lipner, *The Security Development Lifecycle*. Redmond, WA, USA: Microsoft Press, 2006.
- [6] A. Shostack, *Threat Modeling: Designing for Security*. Indianapolis, IN, USA: Wiley, 2014.
- [7] T. B. Brown, B. Mann, N. Ryder, et al., “Language Models are Few-Shot Learners,” in *Advances in Neural Information Processing Systems*, vol. 33, pp. 1877–1901, 2020.
- [8] T. Kojima, S. S. Gu, M. Reid, Y. Matsuo, and Y. Iwasawa, “Large Language Models are Zero-Shot Reasoners,” in *Advances in Neural Information Processing Systems*, vol. 35, pp. 22199–22213, 2022.
- [9] J. Wei, X. Wang, D. Schuurmans, et al., “Chain-of-Thought Prompting Elicits Reasoning in Large Language Models,” in *Advances in Neural Information Processing Systems*, vol. 35, pp. 24824–24837, 2022.
- [10] A. AbdulGhaffar and A. Matrawy, “LLMs’ Suitability for Network Security: A Case Study of STRIDE Threat Modeling,” arXiv:2505.04101, 2025.
- [11] Z. Wu et al., “ThreatModeling-LLM: Automating Threat Modeling using Large Language Models for Banking System,” arXiv:2411.17058, 2024.
- [12] Authors of the ACM 2024 reference topology, “A Study on Network Architectures and Security for SME,” *Proc. ACM Conf.*, 2024, doi:10.1145/3773365.3773603.
- [13] R. Khan, K. McLaughlin, D. Lavery, and S. Sezer, “STRIDE-based threat modeling for cyber-physical systems,” in *Proc. IEEE PES ISGT-Europe*, Turin, Italy, 2017, pp. 1–6.
- [14] W. Xiong and R. Lagerström, “Threat modeling—A systematic literature review,” *Computers & Security*, vol. 84, pp. 53–69, 2019.
- [15] A. Prasad, S. Saha, X. Zhou, and M. Bansal, “ReCEval: Evaluating Reasoning Chains via Correctness and Informativeness,” in *Proc. EMNLP*, 2023, pp. 9999–10018.
- [16] K. Sveidqvist, “Mermaid: Generation of Diagrams and Flowcharts from Text,” 2024. [Online]. Available: <https://github.com/mermaid-js/mermaid>
- [17] T. Cao et al., “A Theoretical Analysis of the Number of Shots in Few-Shot Learning,” arXiv:1909.11722, 2019.
- [18] C. D. Manning, P. Raghavan, and H. Schütze, *Introduction to Information Retrieval*. Cambridge University Press, 2008.
- [19] Gemini Team, Google, “Gemini: A Family of Highly Capable Multimodal Models,” Google DeepMind, Tech. Rep., 2024.
- [20] S. Ouyang, J. M. Zhang, M. Harman, and M. Wang, “An Empirical Study of the Non-determinism of ChatGPT in Code Generation,” *ACM Transactions on Software Engineering and Methodology*, 2025.
- [21] J. Cohen, “A Coefficient of Agreement for Nominal Scales,” *Educational and Psychological Measurement*, vol. 20, no. 1, pp. 37–46, 1960.
- [22] N. F. Liu, K. Lin, J. Hewitt, et al., “Lost in the Middle: How Language Models Use Long Contexts,” *Transactions of the Association for Computational Linguistics*, vol. 12, pp. 157–173, 2024.
- [23] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, “Not What You’ve Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection,” in *Proc. 16th ACM Workshop on Artificial Intelligence and Security*, pp. 79–90, 2023.